Análise de arquivo suspeito

Share

exec.out

OUT

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Consultando o guia de leitura de arquivos antes de prosseguir

Vou começar consultando as instruções de leitura de arquivos e depois fazer a análise estática (sem executar o arquivo em nenhum momento).

Read a file, ran a command

É um executável ELF de 64 bits (Linux), pequeno (~31 KB) e **não stripped** (mantém símbolos, o que ajuda bastante). Agora vou inspecionar cabeçalhos, bibliotecas e funções importadas.

Ran 7 commands

Antes de fechar o veredito, quero checar se esse conjunto de indicadores coincide com o que relatórios públicos de segurança descrevem, em vez de confiar só na minha memória.

Searched the web

Fiz uma análise **estática**: o arquivo foi só lido e inspecionado, nunca executado.

1. Identificação

- Apesar da extensão `.out`, é um executável **ELF 64 bits para Linux x86-64** (PIE, 31.960 bytes).
- SHA-256: `521b34e4b170c57fa708956a0cbae7fc67be6dd6cf0f5945067bc1d2e9114f7e`
- Foi compilado com GCC 14.2.0 (Debian) e **não foi stripped**, então os nomes das funções foram preservados.
- A versão do compilador é recente. Isso sugere que o binário foi recompilado a partir de código-fonte e não é uma amostra antiga coletada em produção.

2. Estrutura

O layout é normal: sem empacotador (UPX etc.), sem seções anômalas, e só depende da `libc`. Isso é neutro por si só, e o que pesa vem nos próximos passos.

3. Funções importadas

- **Rede:** `socket`, `bind`, `listen`, `accept`, `connect`, `recvfrom`, `sendto`, `setsockopt`.
- **Shell remoto:** `fork`, `setsid`, `dup2`, `execve`, `system`, mais `grantpt`, `unlockpt`, `ptsname`, `ioctl` e `vhangup` (alocação de pseudo-terminal).
- **Disfarce e anti-forense:** `prctl` (renomear o processo), `utimes` (alterar datas de arquivos), `unlink` (apagar arquivos).

Esse conjunto é o de um servidor de shell camuflado, não o de uma ferramenta comum.

4. Nomes de funções internas
`rc4`, `crypt_ctx` / `decrypt_ctx`, `cread` / `cwrite`, `getshell`, `shell`, `logon`, `packet_loop` e `set_proc_name`. Indicam comunicação cifrada, autenticação, shell remoto, captura de pacotes e troca do nome do processo.

5. Strings embutidas

- Dez nomes de daemons legítimos (`/sbin/udevd -d`, `dbus-daemon --system`, `/sbin/auditd -n`, `systemd-journald`…), usados para se esconder na lista de processos.
- Copia-se para `/dev/shm` (RAM), dá `chmod 755`, executa a cópia com `--init` e depois a apaga.
- Cria o arquivo PID `/var/run/haldrund.pid`, nome que imita o serviço HAL.
- Executa comandos `iptables` que adicionam e removem regras de redirecionamento (NAT) e de liberação (INPUT) para um IP de origem específico, abrindo caminho pelo firewall.
- Abre um shell com `HISTFILE=/dev/null` e `MYSQL_HISTFILE=/dev/null` (sem histórico), com nome de processo de daemon de e-mail.

6. Verificação no disassembly

- `main()` checa se já existe uma instância (arquivo PID) e o UID, sorteia um dos nomes falsos, renomeia o processo, faz `fork` e `setsid`, grava o PID e entra em `packet_loop()`.
- Lá ele abre `socket(AF_PACKET, SOCK_RAW, htons(ETH_P_IP))` e anexa um filtro BPF (`SO_ATTACH_FILTER`). Isso indica um backdoor **passivo**, que observa o tráfego e só age ao receber pacotes específicos.

7. Comparação com relatórios públicos
O conjunto coincide com o backdoor **BPFDoor**:

- O implante se camufla escolhendo ao acaso um entre dez nomes fixos de processos de sistema. scmagazine
- Ele se copia para /dev/shm/kdmtmpflush, reexecuta com a flag --init, cria o arquivo PID /var/run/haldrund.pid e apaga a cópia. sandflysecurity
- O shell remoto assume o nome de um processo do Postfix e usa variáveis de ambiente que desativam o histórico. countercraftsec
- Uma string fixa em `main()` (iniciada por `justforf…`) bate com o nome pelo qual o implante é rastreado publicamente, "JustForFun". scworld

Relatórios atribuem o BPFDoor ao grupo chinês Red Menshen, ativo desde 2018. Isso não significa que este exemplar tenha vindo desse grupo. scworld

Conclusão: é malware

O arquivo é um **backdoor (RAT) para Linux**, com confiança muito alta. Nenhum software legítimo reúne ao mesmo tempo:

- camuflagem como daemons do sistema;
- socket bruto com filtro BPF;
- autocópia para `/dev/shm` com autoexclusão;
- alteração de regras de firewall para um IP específico;
- shell sem histórico.

Ressalvas:

- A análise foi só estática, e não consultei bases externas de reputação porque a rede desta sandbox está desativada.
- O binário pode ter sido compilado para estudo, laboratório ou CTF. Mesmo assim, é funcionalmente um backdoor.
- Omiti de propósito detalhes operacionais (valores de ativação, credenciais embutidas, protocolo), que não são necessários para o veredito.

O que fazer:

- **Não execute o arquivo** fora de uma VM isolada e sem rede.
- Consulte o SHA-256 no VirusTotal para corroborar.
- Se ele veio de um servidor real, trate como incidente: isole a máquina, preserve evidências antes de reiniciar (parte dos artefatos fica em RAM) e reconstrua a partir de uma base confiável.
- Para procurar indícios no host:
  - arquivos suspeitos em `/dev/shm` e a existência de `/var/run/haldrund.pid`;
  - `ss -0pb` como root, que lista processos com socket de pacotes e filtro BPF;
  - `ls -l /proc/<PID>/exe` em processos com nome de daemon, para ver o binário real;
  - regras `REDIRECT` desconhecidas em `iptables -t nat -S`.